

API Design Standards

Asteria Digital Services | ADS-API-STD-001 | Version 1.4 | Effective 2026-07-01

Owner: Enterprise Architecture

Synthetic training document - created for the Week 2 RAG project. No real company policy is represented.

1. Purpose and Scope

This standard defines mandatory design rules for REST APIs exposed by Asteria Digital Services. It applies to internal, partner-facing, and internet-facing APIs.

2. Authentication and Transport Security

- Internet-facing and partner-facing APIs **MUST** use OAuth 2.0 or OpenID Connect (OIDC).
- Internal service-to-service APIs **SHOULD** use workload identity or OAuth 2.0 client credentials. Basic Authentication is not permitted for new APIs.
- All API traffic **MUST** use TLS 1.2 or higher. Plain HTTP is not permitted outside isolated local development.
- Access tokens, refresh tokens, API keys, passwords, and client secrets **MUST NOT** be placed in URL query parameters.

Additional secret-storage and privileged-access requirements are defined in the Cloud Security Policy.

3. Resource and Versioning Conventions

- Use plural nouns for resource collections, for example /customers and /orders.
- Use HTTPS methods according to intent: GET for retrieval, POST for creation or command submission, PUT for full replacement, PATCH for partial update, and DELETE for removal.
- Breaking changes **MUST** use a new major API version. The preferred URI convention is /v1, /v2, and so on.
- Non-breaking additions such as optional response fields do not require a new major version.

4. Standard Error Contract

All error responses **MUST** contain errorCode, errorMessage, correlationId, and an ISO 8601 UTC timestamp.

Internal stack traces, SQL statements, host names, secrets, and raw exception objects **MUST NOT** be returned to API consumers.

5. Correlation and Observability

- Clients **MAY** send an X-Correlation-ID header. If absent, the API **MUST** generate one.

- The same correlation identifier SHOULD be propagated to downstream synchronous calls and asynchronous messages.
- API access logs MUST follow the Logging & Monitoring Standard and must not contain prohibited sensitive data.

6. Resilience and Performance

- APIs MUST define explicit downstream timeouts; an unbounded network timeout is not allowed.
- Clients SHOULD retry only transient failures and only when the operation is safe to retry.
- POST operations that can create duplicates SHOULD support an idempotency key when retry behavior is expected.
- HTTP 429 SHOULD be used when a client exceeds an enforced rate limit. Include Retry-After when a retry time can be estimated.

7. Data Handling

API payloads containing Confidential or Restricted information are subject to the Data Classification Policy. Restricted data MUST NOT be written to normal application logs. Confidential data may be logged only in masked or tokenized form when the Logging & Monitoring Standard permits it.

8. Quick Reference

Topic	Standard
External API authentication	OAuth 2.0 or OIDC
Minimum transport	TLS 1.2+
Required error fields	errorCode, errorMessage, correlationId, timestamp
Rate limit response	HTTP 429

Related: CSP-SEC-004 Cloud Security Policy; LMS-OPS-003 Logging & Monitoring Standard; DCP-DATA-002 Data Classification Policy; AER-API-005 API Error Code Reference.